WPC 25 ANNI

27|28|29.11.18 / MILANO

27|28|29.11.18

La più importante conferenza Italiana sulle tecnologie Microsoft

25 ANNI DI INNOVAZIONE

OverNet EDUCATION

Mettere in sicurezza ambienti SQL Server

GIANLUCA HOTZ

Chi sono

- Gianluca Hotz | @glhotz | ghotz@ugiss.org
- Consulente indipendente, fondatore e Mentor SolidQ
  - 20+ anni con SQL Server (dalla 4.21 nel 1996)
  - Modellazione e sviluppo basi di dati, dimensionamento e amministrazione, aggiornamento e migrazioni, ottimizzazione prestazioni
- Interessi
  - Modello relazionale, architettura DBMS, sicurezza, alta disponibilità e Disaster Recovery
- Community
  - 20 anni Microsoft MVP SQL Server (dal 1998)
  - Fondatore e presidente UGISS
    - User Group Italiano SQL Server (PASS Chapter)

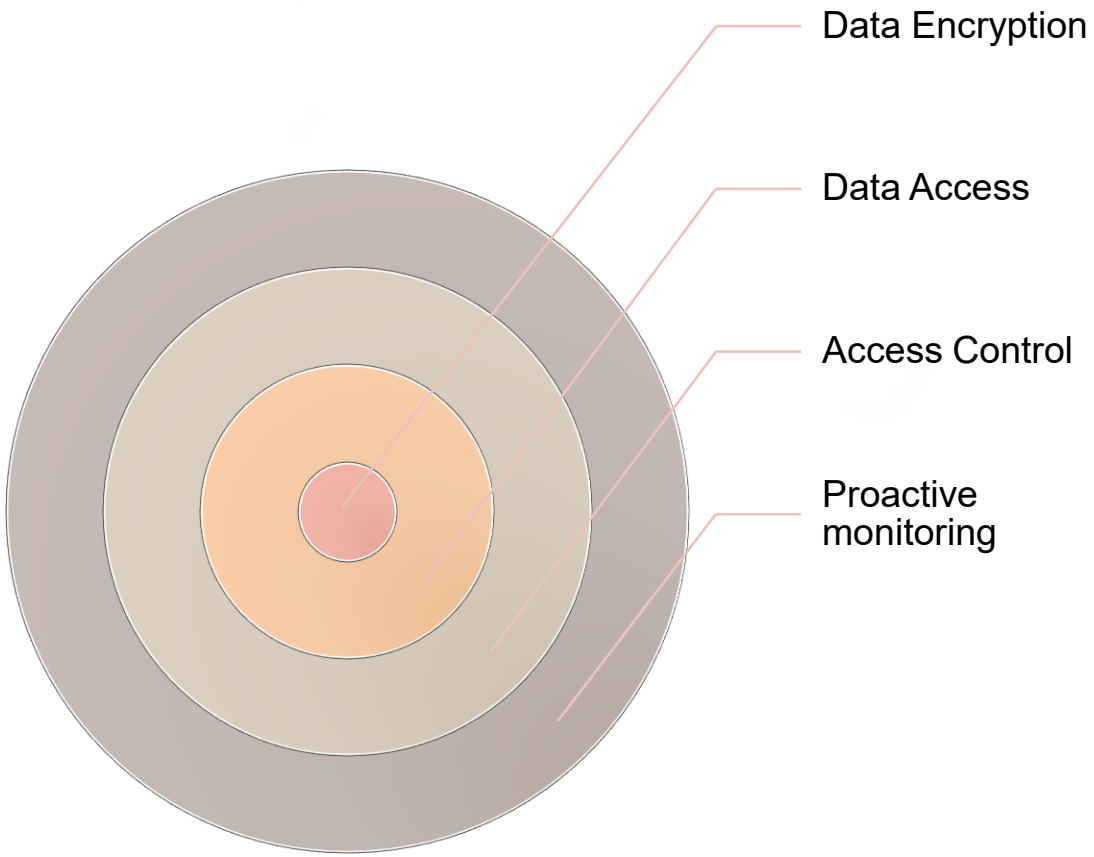
SolidQ

Microsoft Most Valuable Professional

Agenda

- Introduzione
- Scoperta e controllo accessi
- Protezione
  - Always Encrypted
  - Row Level Security
  - Dynamica Data Masking
- Report e revisione

Security Layering



Data Encryption

- **Transport Layer Security (in transit)**
- **Transparent Data Encryption (at rest)**
- **Cell-Level Encryption (at rest)**
- **Always Encrypted (at rest and in transit)**

Data Access

- **Dynamic Data Masking**
- **Row-Level Security**

Access Control

- **Encrypted Authentication**
- **SQL Firewall***

Proactive monitoring

- **Auditing**
- **Threat Detection***

WPC 25 ANNI
27|28|29.11.18 / MILANO

OverNet EDUCATION

Scoperta & Controllo accessi

Mettere in sicurezza ambienti SQL Server

Assessment

- Trovare a classificare informazioni in ambito
  - Catalogo metadati (es. sys.columns, moduli SQL)
  - Ricerche Full-Text in campi liberi
- Valutare necessità e proporzionalità protezioni
  - nome, e-mail, carta di credito, malattie, affiliazione politica ecc.
- Mappare flussi da/verso esterno
- Stato dell’arte rispetto a
  - Best Practice
  - Codice condotta/certificazione

DEMO

Classificazione e Data Discovery con SSMS

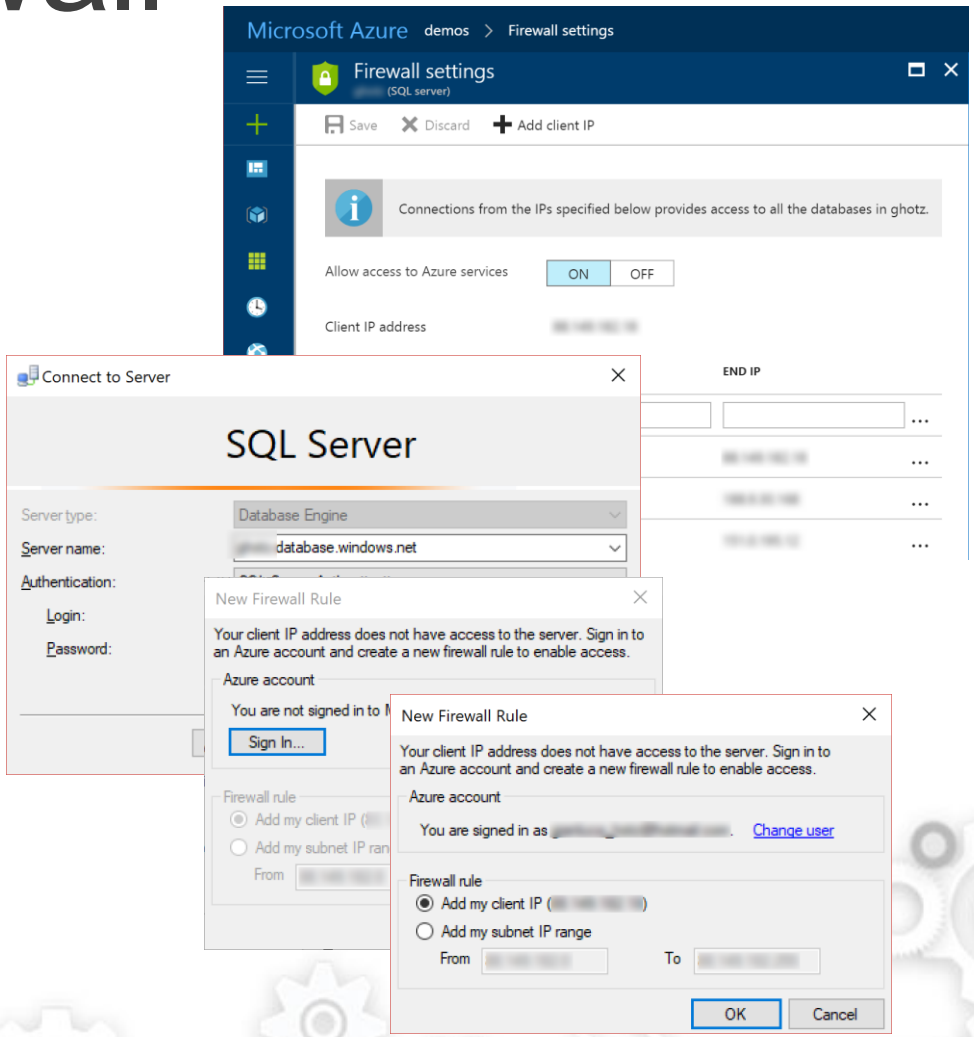
Controllo degli accessi

- Azure Database Firewall (che device)
- Autenticazione (chi sono)
- Autorizzazioni (cosa posso fare)

- Principio guida: minor privilegio!

Azure Database Firewall

- Accesso per servizi Azure
  - Indirizzi IP Specifici
  - Range di indirizzi IP
    - No 0.0.0.0-255.255.255.255 ☺
- Interfaccia SSMS
- Comandi T-SQL
- PowerShell, REST API



Autenticazione

- Due livelli: Server login e Database User
- Nativa SQL Server
- Integrata con Active Directory
  - Utilizza protocollo Kerberos
  - Supporto Azure Active Directory
  - Supporto Active Directory Universal Authentication
    - Multi-factor Authentication (es. via telefono)
    - Supportata solo con SSMS a partire dalla versione 17
- Best Practice
  - Autenticazione integrata
  - Database Containment (autenticazione a livello database)

Autorizzazioni

- Permessi granulari
  - GRANT cosa può fare ON su che oggetto TO chi
  - Ereditarietà gerarchia di oggetti
  - Assegnazione (GRANT), negazione (DENY), revocare (REVOKE)
  - Row Level Security
- Ruoli a livello di server e database
  - Es. sysadmin, dbcreator, db_datareader, db_datawriter
  - Specifici per alcune funzionalità (database msdb)
- Principio guida: minor privilegio!
  - Possibile elevare temporaneamente
    - Impersonation
    - Stored Procedure (in generale moduli T-SQL firmati)

Protezione

Mettere in sicurezza ambienti SQL Server

Attore principale: crittografia, ma dove?

- Dati in transito
  - Autenticazione (sempre crittografata)
  - Spostamento dati
    - invio richieste (parametri)
    - caricamento in memoria
    - invio risposte (record set)
- Dati a riposo
  - File database (dati e log transazioni)
  - File di trace/audit

Crittografia comunicazioni

- On-premise
  - Installazione Certificato (server e client)
  - Possibile forzare utilizzo (server e client)
  - Autenticazione sempre crittografata (nel caso «self-signed»)
- Azure SQL Database (e SQL Data Warehouse)
  - Connessione crittografata sempre necessaria!
  - Es. connessione ADO.NET Encrypt=True;TrustServerCertificate=False
- Transport Layer Security (TLS) 1.2
  - Windows Server 2008 R2
  - SQL Server 2008 SP4 (hotfix)

Crittografia dati prima di SQL Server 2016

- Transparent Data Encryption (TDE)
  - File dati, log e backup
  - Dati decifrati quando caricati in memoria*
  - Completamente trasparente per le applicazioni
- Cell-Level Encryption (CLE)
  - Granularità a livello di Colonna
  - Protezione parziale in memoria
  - Non trasparente per le applicazioni
- Entrambi meccanismi crittografici Server-Side
  - Protezione dati a riposo (es. furto dischi o backup)
  - Utenti con privilegi elevati possono ottenere accesso ai dati

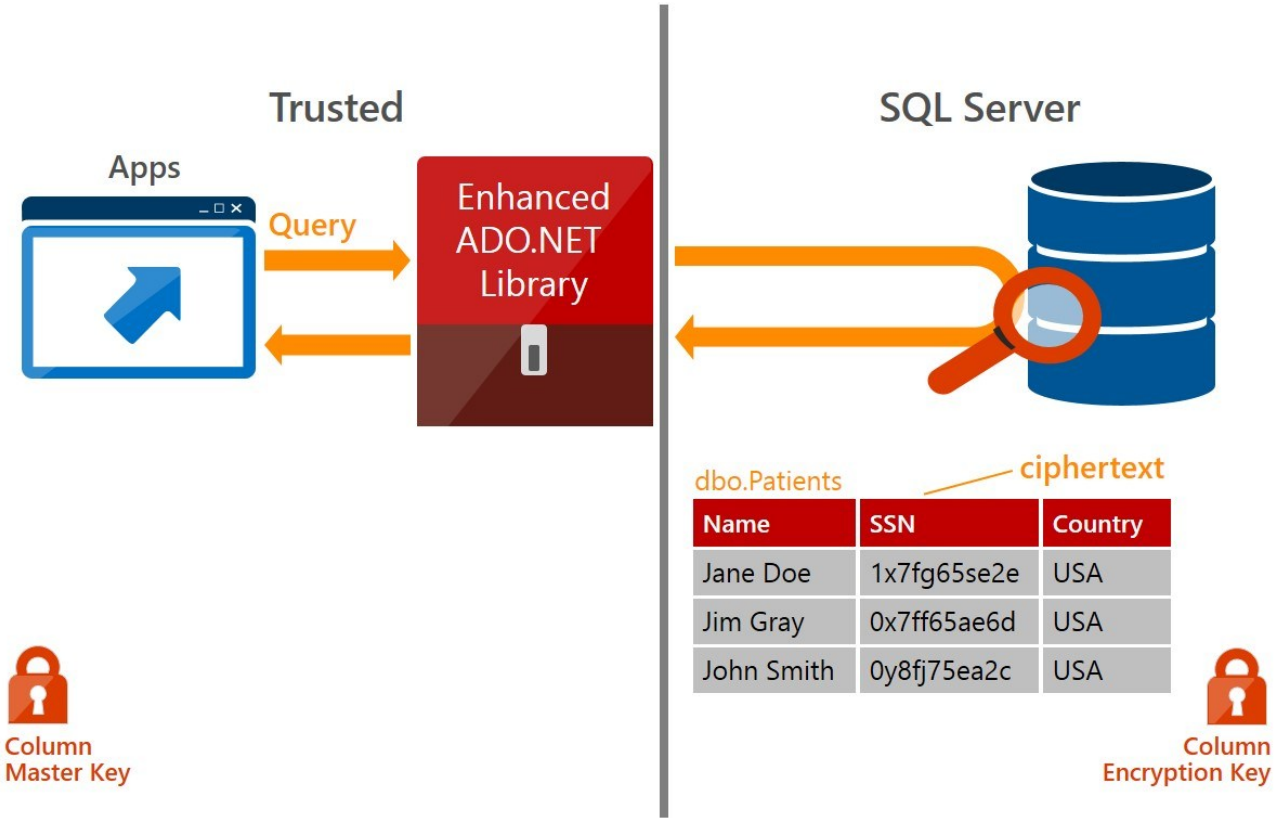
WPC 25 ANNI
27|28|29.11.18 / MILANO

OverNet EDUCATION

Always Encrypted

Mettere in sicurezza ambienti SQL Server

Panoramica Always Encrypted

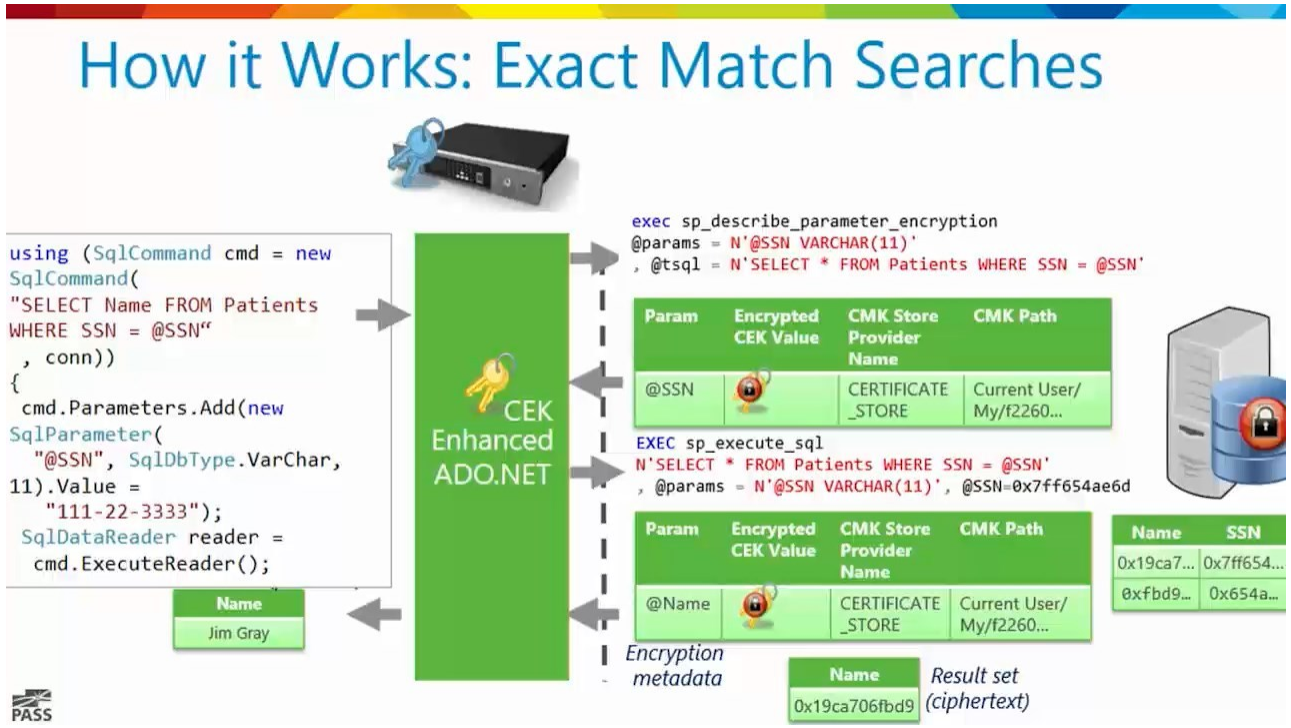


Name	SSN	Country
Jane Doe	1x7fg65se2e	USA
Jim Gray	0x7ff65ae6d	USA
John Smith	0y8fj75ea2c	USA

Crittografia dei dati

- Deterministica
  - Permette operazioni di uguaglianza/raggruppamento/join
  - Permette indicizzazione
  - Più debole es. domini con pochi valori come sesso o «flag»
  - Richiede collation _BIN2
- Casuale
  - Nessuna operazione permessa
  - Indicizzazione non permessa
  - Più robusta

Corrispondenze esatte con Always Encrypted



DEMO

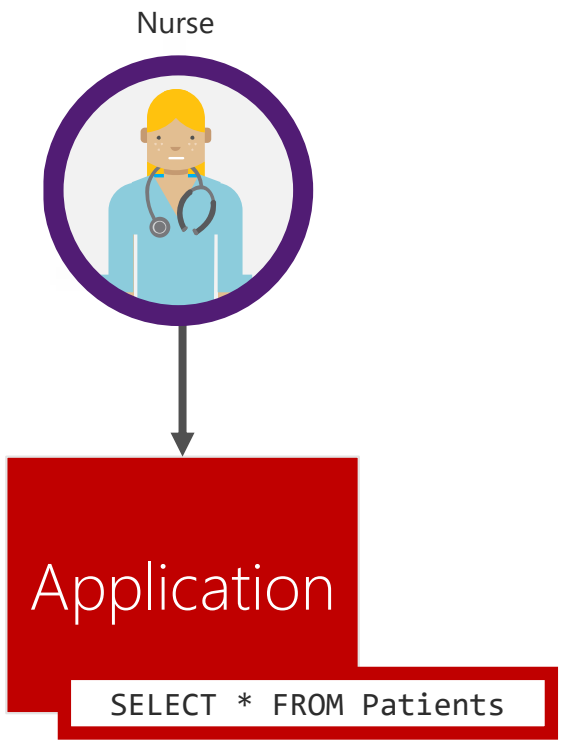
Always Encrypted

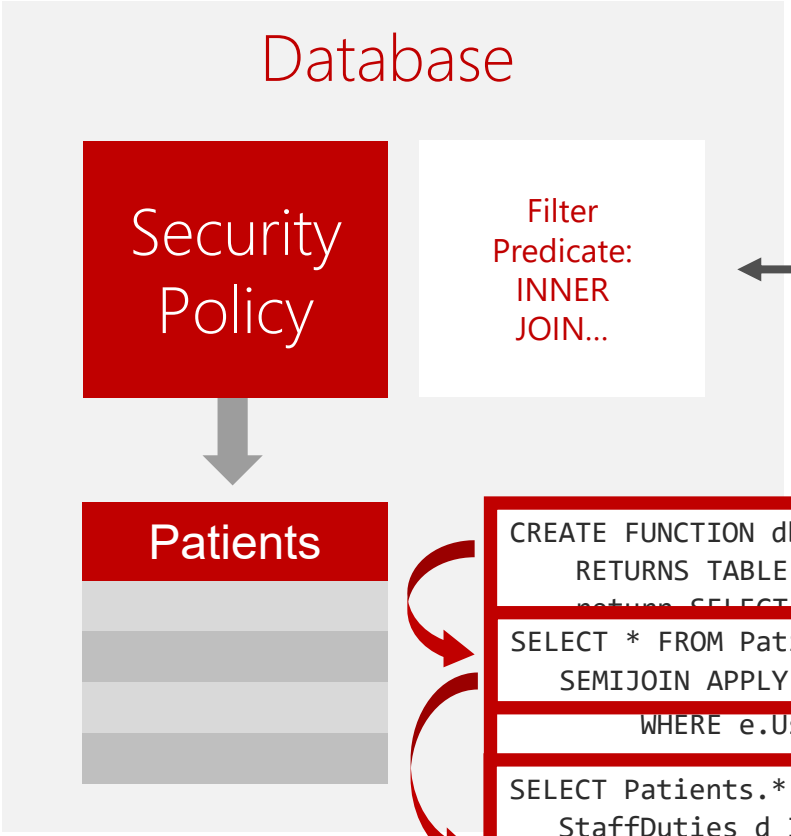
Row Level Security

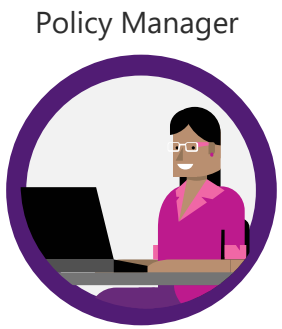
Mettere in sicurezza ambienti SQL Server

«Row-Level Security»

L'utente dell'infermiere è associato a una particolare area di lavoro. Policy di sicurezza. T-SQL, vincolando il predicato alla tabelle dei pazienti.








```
CREATE FUNCTION dbo.fn_securitypredicate(@wing int)
    RETURNS TABLE WITH SCHEMABINDING AS
    return SELECT 1 as [fn_securitypredicate_result] FROM
SELECT * FROM Patients
   SEMIJOIN APPLY dbo.fn_securitypredicate(patients.Wing);
        WHERE e.UserSID = SUSER_SID() AND @wing = d.Wing;
SELECT Patients.* FROM Patients,
   StaffDuties d INNER JOIN Employees e ON (d.EmpId = e.EmpId)
   WHERE e.UserSID = SUSER_SID() AND Patients.wing = d.Wing;
```

DEMO

Row Level Security

WPC 25 ANNI
27|28|29.11.18 / MILANO

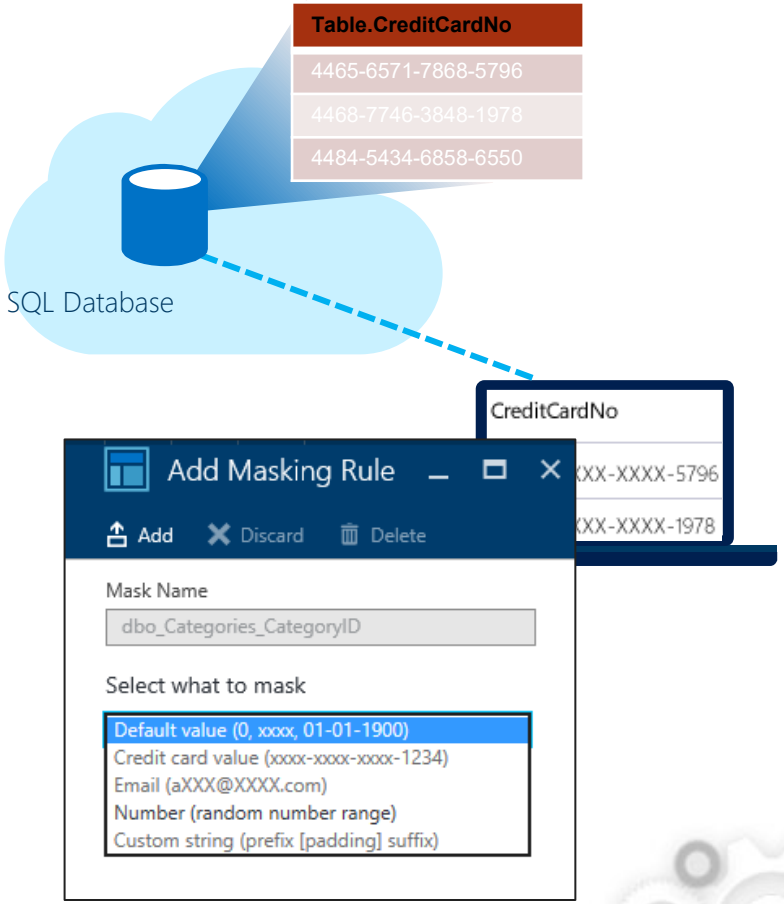
OverNet EDUCATION

Dynamic Data Masking

Mettere in sicurezza ambienti SQL Server

Dynamic Data Masking

- Mascheramento
  - Real-time
  - Diversi tipi di maschere
  - Mascheratura parziale
- Basato su regole/permessi
  - A livello di colonna
  - Permesso di «unmask»
- Configurazione Azure nel portale



DEMO

Dynamic Data Masking

Report e revisione

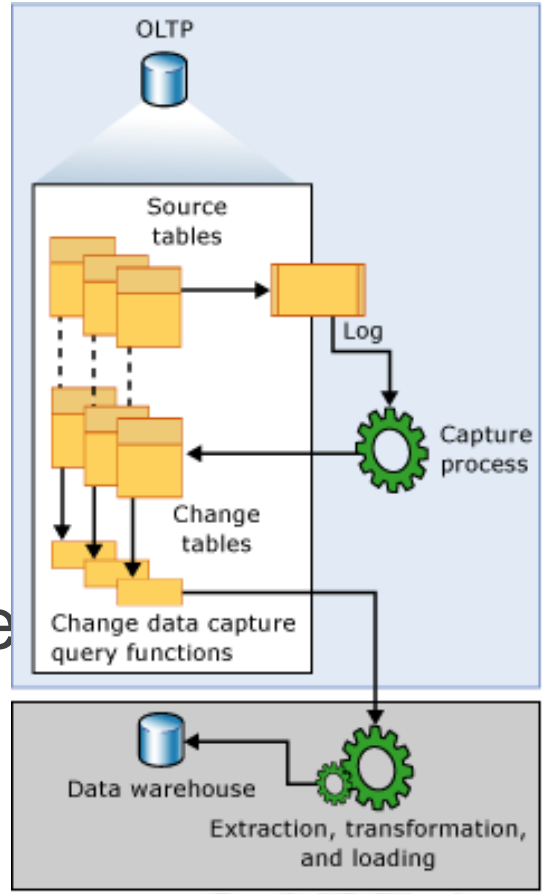
Mettere in sicurezza ambienti SQL Server

Cosa tracciare

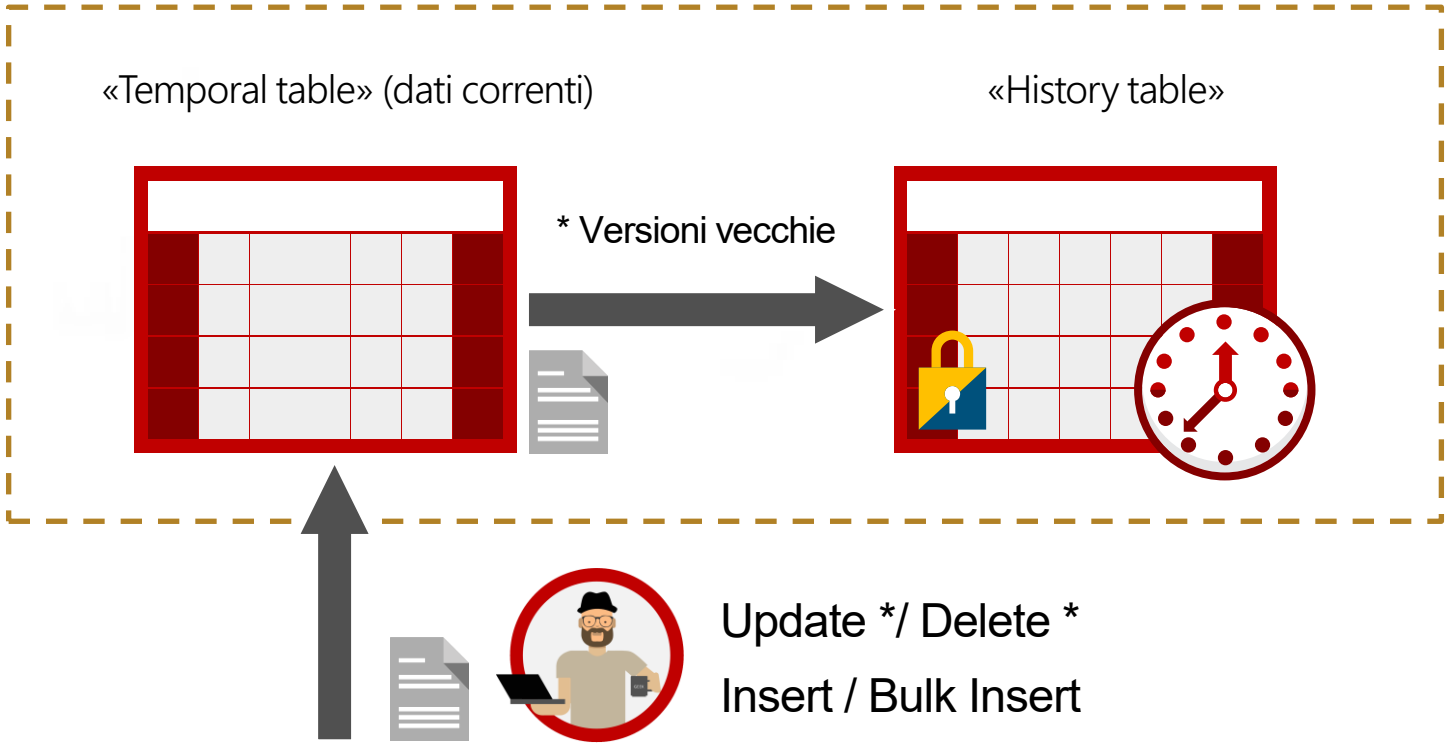
- Accessi
  - SQL Server Trace (Profiler, deprecato)
  - SQL Server Audit
- Dati modificati (versioni precedenti)
  - Change Data Capture
  - Temporal Databases

Change Data Capture

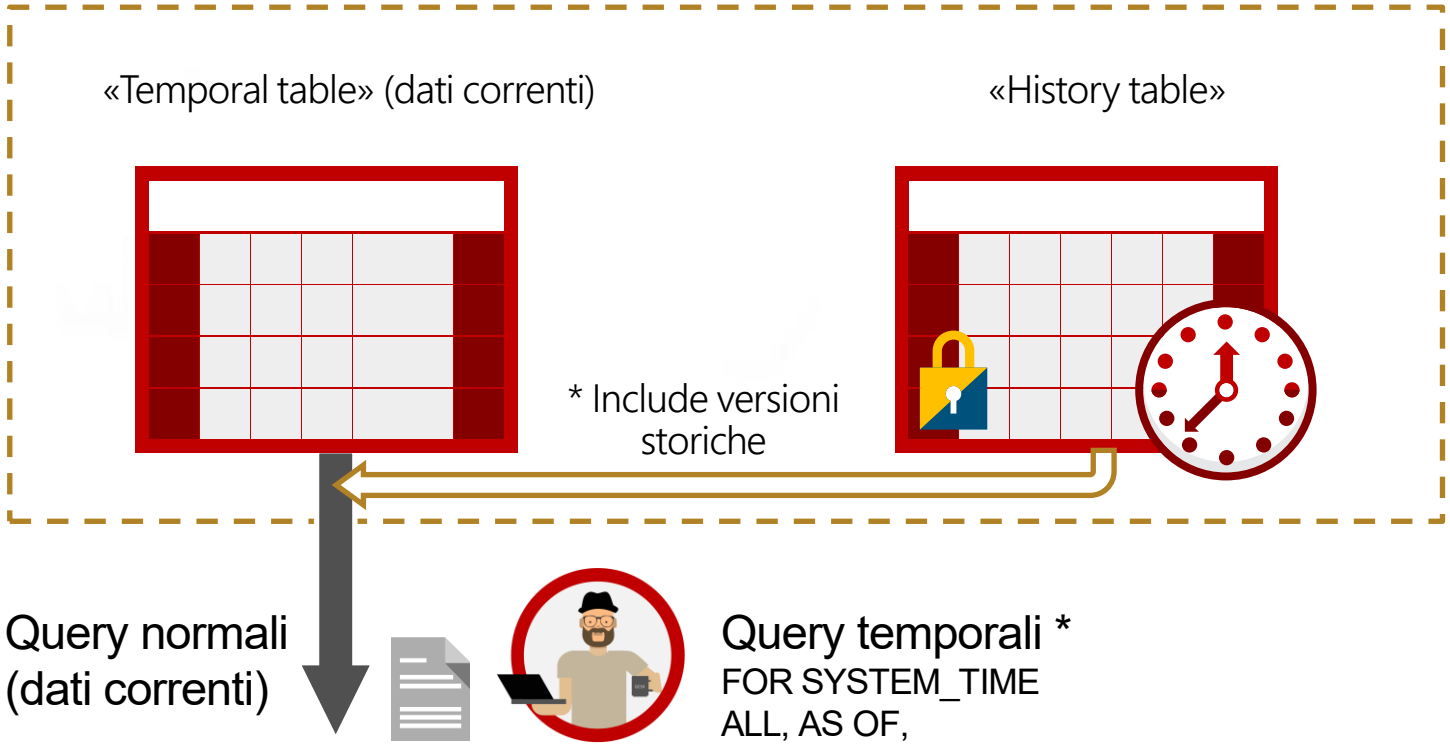
- Soluzione tradizionale Audit modifiche dati?
  - Trigger! Ma…
  - …complessità, prestazioni… ☹
- CDC cattura automaticamente modifiche
  - Pensato principalmente per caricare DWH
  - Genericamente va bene per tenere storico modifiche



Modifiche Database Temporali



Interrogazioni Database Temporali



Query temporali *
FOR SYSTEM_TIME
ALL, AS OF,
BETWEEN … AND …, FROM … TO,
CONTAINED IN

Azure SQL Database Threat Detection

- Semplice opzione da attivare per database
  - Richiede attivazione «SQL Database Auditing»
- Rileva potenziali minacce/vulnerabilità
  - Attacchi di tipo «SQL Injection»
  - Accessi anomali (es. da luoghi anomali)
- Allarmi
  - In tempo reale
  - Raccomandazioni cosa investigare/come mitigare/rimediare

DEMO

VULNERABILITY ASSESSMENT

Q&A

- Domande e risposte

Contatti

ROZZANO (MI)
BOLOGNA
ROMA
GENOVA
TORINO
NAPOLI

- OverNet Education
- Info@OverNetEducation.it
- www.OverNetEducation.it
- Rozzano (MI)+39 02 365738
- Bologna +39 051 269911

- www.wpc-overneteducation.it